

Module Title: Lesson 1 – Security Domains

Total Duration: 10 Hours

Module Overview

This module presents a comprehensive discussion of **Information Assurance and Security (IAS)** and the concept of **Security Domains**. It aims to build strong security awareness among students by explaining how security concerns affect individuals, organizations, and society. The lesson emphasizes that security is not limited to technology alone but spans human behavior, software development, networks, platforms, system administration, system architecture, web applications, and physical facilities.

Students will explore both **shared security concerns** (such as confidentiality, integrity, and availability) and **domain-specific security concerns** unique to particular areas. Through discussions, examples, quizzes, activities, and exercises, learners will develop analytical skills and practical understanding relevant to ICT and system development professions.

Learning Outcomes

At the end of this lesson, students must be able to:

1. Discuss the impact of Information Assurance and Security (IAS) on society and on one's professional and personal practice.
 2. Explain and give examples of **shared security concerns** across selected security domains.
 3. Explain and give examples of **domain-specific security concerns** in specific security domains.
-

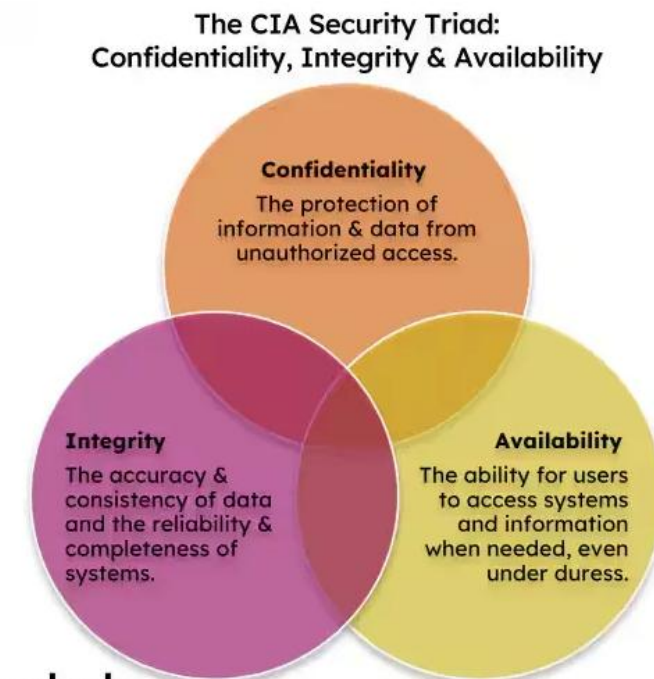
Lesson Proper and Detailed Discussion

Topic 1: Security Awareness (2 Hours)

Discussion:

Security awareness refers to the understanding of potential threats, risks, and responsibilities related to information systems. Information Assurance and Security (IAS) ensures that information is protected and remains trustworthy. A lack of security awareness can result in data breaches, identity theft, financial loss, and loss of public trust.

The foundation of IAS is the **CIA Triad**:



Confidentiality

Confidentiality, a core principle of information security (*part of the CIA Triad*), ensures sensitive data is kept secret and only seen by authorized individuals or systems, preventing unauthorized viewing, sharing, or theft through methods like encryption, access controls (passwords, permissions), and strong authentication (MFA). It protects privacy, maintains trust, ensures compliance, and prevents harm like identity theft or reputational damage by strictly limiting who can access what.

Key aspects of confidentiality:

- ✓ **Protection:** Safeguards data from unauthorized access, disclosure, or theft.
- ✓ **Authorization:** Relies on strict rules and permissions to control access, ensuring only authorized users can view information.
- ✓ **Privacy:** Keeps sensitive information, like financial, medical, or business data, private.
- ✓ **Mechanism:** Achieved through technical controls like encryption, access controls, authentication (e.g., MFA), data classification, and secure channels.

How it's maintained:

- ✓ **Encryption:** Scrambles data so it's unreadable without the correct key.
- ✓ **Access Controls:** Implements rules (e.g., file permissions, door codes) to define who can see what.
- ✓ **Strong Authentication:** Uses passwords, multi-factor authentication, and user verification to confirm identity.

- ✓ **Policies:** Establishes rules for data handling, usage, and sharing.

Why it's important:

- ✓ **Prevents Breaches:** Stops unauthorized parties from accessing confidential data.
- ✓ **Builds Trust:** Shows respect for privacy, fostering trust with customers and partners.
- ✓ **Ensures Compliance:** Meets legal and regulatory requirements (like GDPR, HIPAA).
- ✓ **Mitigates Risk:** Protects against financial loss, identity theft, and reputational damage.

Integrity

Information integrity refers to the assurance that data is accurate, complete, and has not been improperly altered or destroyed in an unauthorized manner. This principle is a foundational component of the CIA triad of information security (Confidentiality, Integrity, and Availability).

Key aspects of ensuring information integrity include:

- ✓ **Accuracy and Consistency:** Data must be correct at all stages of its lifecycle, from creation to storage and retrieval.
- ✓ **Trustworthiness:** Users must be able to trust that the information they access is reliable and has not been tampered with.
- ✓ **Protection against Unauthorized Modification:** Security controls are implemented to prevent unauthorized users from making changes to data, whether accidentally or maliciously.

Common methods and technologies used to maintain integrity include:

- ✓ **Access Controls:** Restricting who can view or edit specific information.
- ✓ **Data Validation:** Using rules and checks to ensure data entered into a system is sensible and correct.
- ✓ **Checksums and Hashing:** Cryptographic methods that create unique digital "fingerprints" for data. If even a single character is changed, the fingerprint changes, immediately alerting users to a modification.
- ✓ **Digital Signatures:** Verifying the authenticity and integrity of digital documents or messages using cryptography.
- ✓ **Backup and Recovery:** Maintaining copies of data to restore in the event of corruption or unauthorized deletion

Availability

Availability ensures authorized users can access needed information and systems when required, crucial for business continuity, and involves strategies like redundancy, disaster recovery, backups, and load balancing to counter threats like DoS attacks, failures, and disasters. It's a core part of the CIA Triad (Confidentiality, Integrity, Availability) in cybersecurity, focusing on uptime and preventing unauthorized denial of access.

Key aspects of availability:

- ✓ Accessibility: Data and systems are usable on demand by authorized entities.
- ✓ Reliability: Systems remain functional and deliver data as expected.
- ✓ Resilience: Ability to withstand disruptions (attacks, hardware failure, disasters).

Common threats to availability:

- ✓ **Cyberattacks:** Denial of Service (DoS/DDoS) attacks, ransomware.
- ✓ **Hardware/Software Issues:** Failures, bugs, network outages.
- ✓ **Environmental:** Power outages, natural disasters (fire, flood).
- ✓ **Human Error:** Accidental shutdowns or misconfigurations.

Strategies to ensure availability:

- ✓ Redundancy: Duplicate servers, networks, power supplies (e.g., failover systems).
- ✓ Disaster Recovery & Business Continuity: Plans to restore operations quickly.
- ✓ Regular Backups: Offsite, tested data copies for recovery.
- ✓ Load Balancing: Distributing traffic to prevent server overload.
- ✓ Monitoring: Continuous uptime and performance tracking.
- ✓ Access Controls: Limiting who can make changes.

Examples:

- Using strong passwords to protect confidentiality
- Preventing unauthorized modification of grades or records
- Ensuring online services remain accessible during peak usage

Activity 1: Personal Security Reflection (Individual – 30 minutes)

Students list five online activities they regularly perform and identify possible security risks and preventive measures.

Quiz 1 (Sample):

1. What does the CIA Triad stand for?
2. Give one example of a threat caused by human behavior.

Topic 2: Overview of Security Domains (1 Hour)

Discussion:

Security domains divide complex systems into manageable areas where security controls can be applied effectively. While each domain has unique concerns, many security principles apply across all domains.

Authentication and authorization

Authentication and authorization are the two primary pillars of **Identity and Access Management** (IAM). While often used interchangeably, they serve distinct and sequential roles in securing digital environments.

Key Differences at a Glance

Feature	Authentication (AuthN)	Authorization (AuthZ)
Main Question	"Who are you?"	"What are you allowed to do?"
Core Goal	Verifying identity	Determining access rights
Order	Always happens first	Happens after successful authentication
Common Factors	Passwords, biometrics, OTPs	Roles, permissions, policies

Authentication (AuthN)

Authentication is the process of confirming that a user is who they claim to be. This is typically achieved through one of three factors:

- ✓ Knowledge: Something you *know* (e.g., password, PIN, security questions).
- ✓ Possession: Something you *have* (e.g., physical security token, smartphone for OTPs, key card).
- ✓ Inherence: Something you *are* (e.g., fingerprint, facial recognition, iris scan).

Modern systems increasingly use **Multi-Factor Authentication (MFA)**, which requires more than one factor to grant entry, significantly reducing the risk of unauthorized access.

Authorization (AuthZ)

Once identity is confirmed, authorization determines the specific resources or functions the user can access. Common authorization models include:

- ✓ Role-Based Access Control (RBAC): Permissions are assigned to specific roles (e.g., Admin, Editor, Viewer) rather than individuals.
- ✓ Attribute-Based Access Control (ABAC): Access decisions are made based on attributes of the user, the resource, and the environment (e.g., time of day or location).
- ✓ Least Privilege: A security principle where users are granted only the minimum level of access necessary to perform their jobs.

Real-World Analogy

The Hotel: Showing your ID at the front desk to prove you are the person who booked the room is **authentication**. Receiving a key card that only opens your specific room—and not the manager's office—is **authorization**.

The Airport: Your passport **authenticates** your identity to security. Your boarding pass **authorizes** you to board a specific flight and sit in a specific seat

Data confidentiality

Data confidentiality is the practice of protecting sensitive information from unauthorized access, disclosure, or theft, ensuring only authorized individuals can view it, and is a core part of information security, achieved through measures like encryption, access controls, and training, crucial for privacy and legal compliance in fields like healthcare, finance, and general business. It prevents severe consequences like identity theft, financial loss, and reputational damage.

Key Aspects

- ✓ **Privacy:** Keeping personal and proprietary data secret.
- ✓ **Access Control:** Restricting data viewing/sharing to authorized users.
- ✓ **Security Measures:** Using encryption, passwords, firewalls, and role-based access (RBAC)
- ✓ **Legal Compliance:** Adhering to regulations like the Philippines Data Privacy Act (RA 10173).

Examples of Confidential Data

- ✓ **Personal:** Names, addresses, medical records, Social Security numbers.
- ✓ **Business:** Trade secrets, financial data, customer lists, marketing plans, R&D details.

How It's Maintained

- ✓ **Technical:** Encryption, strong passwords, secure storage, limited master lists.
- ✓ **Administrative:** Staff training, clear policies, regular reviews, destroying unnecessary records.
- ✓ **Legal:** Non-Disclosure Agreements (NDAs) for partners and employees.

Why It Matters

- ✓ **Prevents Harm:** Stops identity theft, misuse of data, and financial fraud.
- ✓ **Maintains Trust:** Builds confidence with customers and partners.
- ✓ **Avoids Penalties:** Protects against legal fines and reputational damage.

Risk management

Risk management is the systematic process of **identifying, assessing, and controlling threats** (risks) to an organization's capital, operations, and reputation, aiming to minimize negative impacts and maximize opportunities by developing strategies and implementing controls to reduce uncertainty and protect objectives. It involves analyzing potential issues like financial, legal, strategic, and safety risks, and creating plans to avoid, reduce, transfer, or accept them, ensuring business continuity and success.

Key Steps in Risk Management

- ✓ Identify Risks: Pinpoint potential hazards from various sources (e.g., market changes, accidents, security breaches).
- ✓ Assess & Analyze Risks: Evaluate the likelihood and potential severity (impact) of each identified risk.
- ✓ Prioritize Risks: Rank risks based on their potential impact and probability to focus efforts
- ✓ Treat/Mitigate Risks: Develop and implement strategies to manage risks (e.g., elimination, reduction, transfer via insurance, acceptance).
- ✓ Monitor & Review: Continuously track risks, the effectiveness of controls, and adapt to new threats.

Why It's Important

- ✓ Protects Assets: Safeguards financial stability, physical assets, and reputation.
- ✓ Ensures Continuity: Helps organizations prepare for disruptions, minimizing downtime.
- ✓ Informs Decisions: Provides a framework for making safer, more informed choices.
- ✓ Seizes Opportunities: Helps identify and capitalize on positive risks (opportunities) as well as negative threats.

Examples of Risks Managed

- ✓ Financial: Economic downturns, credit defaults.
- ✓ Operational: Supply chain issues, project failures, accidents.
- ✓ Strategic: Competitor actions, shifts in market demand.
- ✓ Compliance: Legal liabilities, regulatory changes.
- ✓ Security: Cyberattacks, data breaches, physical theft.

Example:

User authentication is required in HCI, networking, and system administration.

Exercise

Identify at least three shared security concerns across HCI, Networking, and Web Systems.

1:

Topic 3: Human-Computer Interaction (HCI) Security Domain (1 Hour)

Discussion:

The HCI Security Domain integrates Human-Computer Interaction (HCI) principles with cyber security, focusing on designing user-friendly interfaces that inherently promote security, address user vulnerabilities (like susceptibility to phishing), and make complex security features usable, bridging the gap between technical security systems and human behavior to reduce errors and enhance overall digital safety. It treats security not just as a technical problem but as a user experience challenge, analysing how humans perceive, understand, and interact with security features.

Weak password practices

Weak password practices involve using short, predictable passwords with dictionary words, personal info (names, birthdays), or simple patterns (12345, qwerty), reusing the same password across many sites, and neglecting complexity (mix of cases, numbers, symbols) or multi-factor authentication (MFA). These habits make accounts easy targets for hackers using automated tools, leading to unauthorized access and data breaches.

Common Weak Password Practices

- ✓ Short Length: Under 12-16 characters, as it limits combinations.
- ✓ Dictionary Words: Using common words, names, or phrases ("password," "dragon").
- ✓ Personal Information: Including names, pet names, birthdays, or addresses.
- ✓ Simple Patterns: Sequential numbers/letters (12345, abcde) or repeated characters (aaaaaa).
- ✓ Site-Specific Words: Using "Amazon" for an Amazon account.
- ✓ Password Reuse: Using the same password for multiple accounts.
- ✓ Minimal Complexity: Lacking a mix of uppercase, lowercase, numbers, and symbols throughout.
- ✓ Predictable Changes: Just swapping the year (e.g., "Password2024!" to "Password2025!").

Strong Password Practices to Adopt Instead

- ✓ Length & Complexity: Aim for 12+ characters with mixed cases, numbers, and symbols.
- ✓ Passphrases: Use a series of random, unrelated words (e.g., "BlueDolphinSunsetDrive").
- ✓ Unique Passwords: One unique password per account.
- ✓ Password Managers: Use tools to generate and store complex, unique passwords.
- ✓ Multi-Factor Authentication (MFA): Enable it everywhere possible for an extra layer of security.

Phishing and social engineering

Phishing is a type of social engineering attack where cybercriminals use deceptive messages (email, text, calls) to trick people into revealing sensitive info (passwords, credit cards) or downloading malware by pretending to be a trusted source.

Social engineering is the broader field of manipulating human psychology, while phishing is its most common form, exploiting trust, urgency, or fear to bypass technical security by targeting human error. Other methods include vishing (voice), smishing (SMS), baiting, pretexting, and tailgating, all aiming to exploit human traits for unauthorized access.

What is Social Engineering?

A broad term for manipulating people to perform actions or divulge confidential information. Exploits human psychology, trust, authority, and urgency. Includes tactics beyond digital messaging, like physical tailgating or dumpster diving.

What is Phishing?

A specific type of social engineering using fraudulent electronic communications.

Methods: Fake emails, texts (smishing), calls (vishing), or malicious websites.

Goal: Get users to click malicious links, open infected attachments, or enter data on fake login pages.

Common Types of Attacks

- ✓ **Phishing (Email):** Bulk emails with urgent requests (e.g., fake invoices).
- ✓ **Smishing (SMS):** Text messages about winnings or delivery issues.
- ✓ **Vishing (Voice):** Phone calls pretending to be from IRS or banks.
- ✓ **Spear Phishing:** Highly targeted phishing aimed at specific individuals/organizations.
- ✓ **Baiting:** Luring victims with enticing offers (free downloads, prizes).
- ✓ **Pretexting:** Creating a fake scenario (e.g., IT support) to gain trust.
- ✓ **Tailgating:** Physically following an authorized person into a secure area.

How to Protect Yourself

- ✓ Be suspicious of unsolicited messages, especially those creating urgency or fear.
- ✓ Verify the sender's identity through a separate, trusted channel.
- ✓ Never provide personal info or click links in suspicious messages.
- ✓ Check URLs carefully before clicking on mobile devices.

Poorly designed authentication interfaces

Poorly designed authentication interfaces create user frustration and introduce significant security vulnerabilities, as they increase the likelihood of user errors and can contain logic flaws that attackers exploit.

Common Characteristics and Consequences

- ✓ **Confusing Layouts:** Inconsistent or cluttered layouts with overlapping elements or unaligned components make it difficult for users to navigate the login process.
- ✓ **Non-Descriptive Error Messages:** Vague error messages that don't clearly inform the user what went wrong (e.g., "Invalid login" instead of "Incorrect password") force users to guess the issue, increasing frustration and potential for lockouts.
- ✓ **Overly Complex Password Requirements:** Requiring a complicated combination of characters that users struggle to remember leads them to choose weak, easily guessable passwords, or forces them to write passwords down, which increases security risks.
- ✓ **Hidden Navigation or Functions:** Vital features like password reset options or multi-factor authentication (MFA) setup pages may be difficult to find or use, leading users to make unsafe choices or avoid necessary security measures.
- ✓ **Ignoring Mobile Optimization:** Authentication interfaces that are not optimized for mobile devices often have tiny touch targets, poor contrast, and unresponsive elements, making the process cumbersome for a large portion of users.
- ✓ **Lack of Feedback:** Not providing clear system status or visual feedback during the login process leaves users uncertain whether their input is being processed, which can lead to multiple, unnecessary attempts and a poor user experience.
- ✓ **Vulnerable Backend Logic:** The most severe flaw can be a lack of strict permission verification on the backend, allowing attackers to bypass the UI entirely by directly accessing internal URLs or altering authentication parameters.

Security Implications

- ✓ **Bad UI design** can be a direct cause of "Identification and Authentication Failures" (previously known as "Broken Authentication"), a critical security risk identified by the [OWASP](#)
- ✓ **User Enumeration:** Poor error handling can allow attackers to determine valid usernames by providing different messages for "user not found" versus "incorrect password".
- ✓ **Brute Force Attacks:** Inadequate account lockout mechanisms or faulty CAPTCHAs can make systems susceptible to automated attacks designed to guess credentials.
- ✓ **Session Hijacking:** Improper session management, such as having sessions that never time out, allows an attacker to hijack an active session if they gain access to the user's device.

To mitigate these risks, designers should focus on creating intuitive, consistent, and simple interfaces that prioritize both usability and strong security principles

Example:

A confusing login page may encourage users to reuse simple passwords.

Activity**2:**

Evaluate a sample login interface and list possible security issues.

Topic 4: Information Management Security Domain (1 Hour)**Discussion:**

Information Management focuses on securing stored and processed data throughout its lifecycle.

Domain-Specific Concerns:**DATA PRIVACY**

Data privacy is the right of individuals to control their personal information, dictating how organizations collect, store, use, and share it, ensuring it's handled responsibly, securely, and ethically, often under laws like the GDPR or Data Privacy Act of 2012 (Philippines). It focuses on individual rights, consent, transparency, and security to prevent misuse, identity theft, and unauthorized access, building consumer trust and avoiding legal penalties.

Key Aspects

- ✓ Individual Control: Users decide who accesses their data (name, location, financial, health info) and for what purpose.
- ✓ Ethical Handling: Ensures data is collected for specific, legitimate reasons and not shared inappropriately.
- ✓ Transparency: Organizations must be clear about their data practices
- ✓ Security: Protects data from breaches, theft, and unauthorized alteration through access controls and safeguards.

Why It's Important

- ✓ For Individuals: Prevents financial fraud, identity theft, and protects sensitive personal details.
- ✓ For Businesses: Builds customer trust, maintains brand reputation, avoids hefty fines, and ensures legal compliance.

Data Privacy vs. Data Security

- ✓ Data Privacy: Focuses on rights and governance—who can access data and for what purpose (e.g., consent).
- ✓ Data Security: Focuses on protection—technical measures (like encryption) to prevent unauthorized access, theft, or loss.
- ✓ Relationship: They are distinct but intertwined; strong security supports privacy, while privacy rules guide security implementation.

DATA CLASSIFICATION

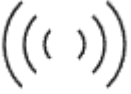
What is data classification?

Data classification is the process of organizing data into categories based on its sensitivity, value and any applicable security or compliance requirements.

By classifying data, organizations can treat information according to its importance rather than handling everything the same way. The result is a sharper focus: data that needs protection receives it, while data meant to move freely can do so without unnecessary barriers.

A thoughtful data classification policy also bridges the gap between technology and trust. It connects how information is stored and secured with how it's actually used, aligning day-to-day operations with long-term goals or governance, analytics and automation. In doing so, data classification helps ensure that valuable data remains both visible and secure from unauthorized access or data breaches.

TYPES OF DATA CLASSIFICATION

	Public data Information intended for open access, such as marketing content or public reports. Disclosure of public information poses minimal risk to the organization.
	Internal data Operational information for employees or approved partners. Accidental exposure may cause inconvenience but not legal liability.
	Confidential data Sensitive information that could cause reputational or financial harm if disclosed, such as financial records, customer lists or proprietary designs.
	Restricted data The most highly protected class, including critical data like credit card numbers, account numbers, driver's license details, biometric identifiers and protected health information (PHI).

ACCESS CONTROL

Access control is a security process that regulates who or what can view, use, or access specific resources, whether digital (data, networks, apps) or physical (buildings, rooms). It works by verifying a user's identity (authentication) and then granting or denying access based on

predefined policies and roles (authorization), ensuring only authorized individuals have appropriate access to sensitive information and areas to prevent unauthorized breaches.

Key Components

- ✓ **Identification:** The user presents credentials (username, badge).
- ✓ **Authentication:** The system verifies the identity (password, biometrics, MFA).
- ✓ **Authorization:** The system checks policies to grant or deny access to specific resources.

Types of Policies/Models

- ✓ **Role-Based Access Control (RBAC):** Access assigned based on job function (e.g., HR, Finance).
- ✓ **Mandatory Access Control (MAC):** Strict, centralized control, often for high-security environments.
- ✓ **Discretionary Access Control (DAC):** Owners control access to their own resources.
- ✓ **Attribute-Based Access Control (ABAC):** Access based on attributes of users, resources, and environment.

Examples in Practice

- ✓ **Digital:** Logging into a website with a password, using multi-factor authentication for a bank account, or a company network restricting file access by department.
- ✓ **Physical:** Key cards for office doors, biometric scanners for data centers, or security guards checking guest lists.

Why It's Important

- Protects sensitive data and prevents breaches.
- Ensures confidentiality, integrity, and availability of resources.
- Helps meet compliance requirements (e.g., HIPAA, GDPR).

Example:

Restricting access to student academic records.

Exercise

2:

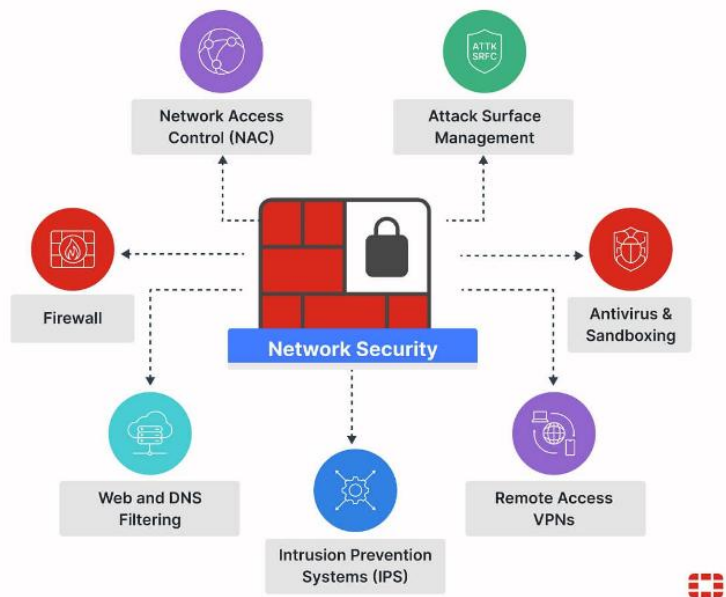
Analyze a case where personal data was leaked and identify what controls failed.

Topic 5: Networking Security Domain (1 Hour)

Network security refers to the technologies, policies, people, and procedures that defend any communication infrastructure from cyber-attacks, unauthorized access, and data loss, while upholding the principles of the CIA triad.

WHAT IS A NETWORK ATTACK?

A network attack is an attempt to gain unauthorized access to an organization's network, with the objective of stealing data or perform other malicious activity.



There are two main types of network attacks:

- **Passive:** Attackers gain access to a network and can monitor or steal sensitive information, but without making any change to the data, leaving it intact.
- **Active:** Attackers not only gain unauthorized access but also modify data, either deleting, encrypting or otherwise harming it.

We distinguish network attacks from several other types of attacks:

- **Endpoint attacks**—gaining unauthorized access to user devices, servers or other endpoints, typically compromising them by infecting them with malware.
- **Malware attacks**—infecting IT resources with malware, allowing attackers to compromise systems, steal data and do damage. These also include ransomware attacks.
- **Vulnerabilities, exploits and attacks**—exploiting vulnerabilities in software used in the organization, to gain unauthorized access, compromise or sabotage systems.
- **Advanced persistent threats**—these are complex multilayered threats, which include network attacks but also other attack types.

In a network attack, attackers are focused on penetrating the corporate network perimeter and gaining access to internal systems. Very often, once inside attackers will combine other types of attacks, for example compromising an endpoint, spreading malware or exploiting vulnerability in a system within the network.

What are the Common Types of Network Attacks?

1. Unauthorized access

Unauthorized access refers to attackers accessing a network without receiving permission. Among the causes of unauthorized access attacks are weak passwords, lacking protection against social engineering, previously compromised accounts, and insider threats.

2. Distributed Denial of Service (DDoS) attacks

Attackers build botnets, large fleets of compromised devices, and use them to direct false traffic at your network or servers. DDoS can occur at the network level, for example by sending huge volumes of SYN/ACC packets which can overwhelm a server, or at the application level, for example by performing complex SQL queries that bring a database to its knees.

3. Man in the middle attacks

A man in the middle attack involves attackers intercepting traffic, either between your network and external sites or within your network. If communication protocols are not secured or attackers find a way to circumvent that security, they can steal data that is being transmitted, obtain user credentials and hijack their sessions.

4. Code and SQL injection attacks

Many websites accept user inputs and fail to validate and sanitize those inputs. Attackers can then fill out a form or make an API call, passing malicious code instead of the expected data values. The code is executed on the server and allows attackers to compromise it.

5. Privilege escalation

Once attackers penetrate your network, they can use privilege escalation to expand their reach. Horizontal privilege escalation involves attackers gaining access to additional, adjacent systems, and vertical escalation means attackers gain a higher level of privileges for the same systems.

6. Insider threats

A network is especially vulnerable to malicious insiders, who already have privileged access to organizational systems. Insider threats can be difficult to detect and protect against, because insiders do not need to penetrate the network in order to do harm. New technologies like User and Event Behavioral Analytics (UEBA) can help identify suspicious or anomalous behavior by internal users, which can help identify insider attacks.

UNSECURE WIRELESS NETWORKS

An unsecured Wi-Fi network lacks password protection and encryption (like WPA2/WPA3), making it easy for anyone nearby, including hackers, to connect and intercept your sensitive data (passwords, bank details, messages) through attacks like snooping or Man-in-the-Middle (MITM). These are common in public places like cafes and airports, and while they often have login screens (captive portals), these offer minimal security, so you should use a VPN, avoid confidential tasks, and turn off sharing when on them.

What it means

- No password/encryption: Anyone can join, and data isn't scrambled.
- Vulnerable to interception: Hackers can "listen" to your traffic (like conversations in a crowded room).
- Types: Can be truly open (no password) or use weak, outdated security (like WEP).
- Risks
- Data theft: Passwords, credit card numbers, personal messages are at risk.
- Malware: Hackers can inject malicious software onto your device.
- Session hijacking: Attackers can take over active website sessions.

How to stay safe

- Use a VPN: Encrypts your traffic, creating a secure tunnel.
- Connect to secure sites: Look for "https://" in website addresses (though a VPN is better).
- Turn off sharing: Disable file, printer, and network sharing.
- Avoid sensitive tasks: Don't log into banks or email.
- Turn off auto-connect: Prevent devices from joining automatically.
- Use cellular data: Better than public Wi-Fi if you have it.

Example:

Using firewalls and VPNs to protect campus networks.

Quiz 2 (Sample):

1. What is a firewall?
2. Why are unsecured Wi-Fi networks risky?

Topic 6: Program Fundamentals Security Domain (1 Hour)

Discussion:

This domain focuses on writing secure software and preventing vulnerabilities during development.

Domain-Specific Concerns:

INPUT VALIDATION ERRORS

Input validation errors occur when data submitted by a user or external system does not meet the criteria expected by the application. These errors are crucial to handle for both security and functionality, as improper validation is the root cause of much vulnerability, including SQL injection and cross-site scripting (XSS).

COMMON TYPES OF INPUT VALIDATION ERRORS

Input validation errors manifest in various forms when the input fails specific checks:

- **Data Type Mismatch:** The input is not the expected type (e.g., entering text in a numerical field).
- **Format/Syntax Errors:** The input does not match a required pattern, such as an invalid email address or phone number format.
- **Range/Length Violations:** The input is outside acceptable minimum/maximum values (e.g., an age of 500 or a password that is too short).
- **Semantic Errors:** The input is syntactically correct but invalid in the context of the application (e.g., a return date that is before the departure date).
- **Missing Required Fields:** The user fails to provide data for a mandatory input field.
- **Consistency Errors:** The input conflicts with other related data in the system.

CONSEQUENCES OF IMPROPER INPUT VALIDATION

Failing to properly validate input can lead to a variety of issues:

- **Security Vulnerabilities:** This is the most significant risk. Malicious input can be used to exploit vulnerabilities like buffer overflows, SQL injection, and XSS attacks.
- **Application Instability:** Processing unexpected or corrupt data can cause the application to return incorrect results, fail, or even crash.
- **Poor User Experience:** If a registration form accepts an invalid email address, the user might be unable to confirm their account, leading to frustration.
- **Data Corruption:** Invalid data can lead to data integrity issues in the database.

INJECTION ATTACKS

Injection attacks exploit application vulnerabilities by inserting malicious input (code, commands, data) through user fields, tricking the system into executing unauthorized actions like data theft, system compromise, or denial of service.

Common types include SQL Injection, which manipulates databases, and Prompt Injection, targeting AI models by altering instructions, with overall risks spanning database queries, OS commands, and more, all stemming from unvalidated input.

HOW THEY WORK

- **Unvalidated Input:** Attackers send specially crafted data (e.g., SQL commands, script snippets) into input fields (forms, URLs, API endpoints) that aren't properly checked (sanitized) by the application.

- **Interpreter Misinterpretation:** The application misinterprets this malicious input as part of its own code or commands, rather than just data
- **Execution:** The system then executes the attacker's injected code, leading to unintended behavior.

COMMON TYPES OF INJECTION ATTACKS

- **SQL Injection (SQLi):** Injects SQL commands to manipulate backend databases, allowing data theft, modification, or deletion.
- **Code Injection:** Injects malicious code (like scripting languages) to execute commands on the server.
- **OS Command Injection:** Injects operating system commands via HTTP requests or other interfaces.
- **Prompt Injection (AI):** Inserts instructions into AI prompts to override original programming, bypass safety filters, or extract data.
- **XPath Injection:** Injects data into XPath queries to access sensitive information in XML documents.

POOR ERROR HANDLING

Poor error handling means a system fails to manage errors effectively, leading to security risks (leaking info to attackers), instability (crashes, denial of service), and bad user/developer experience (frustration, debugging nightmares, churn) by showing cryptic messages or failing silently.

COMMON PROBLEMS WITH POOR ERROR HANDLING:

- **Information Disclosure:** Displaying internal details (database errors, file paths, stack traces) that help attackers understand and exploit vulnerabilities.
- **Denial of Service (DoS):** Unhandled exceptions can crash the application, allowing attackers to overwhelm it with requests to keep it down.
- **Brittle Logic:** Inconsistent or overly generic error messages make it hard for developers to debug and maintain the system.
- **User Frustration:** Cryptic or confusing messages (e.g., "Error 404") without guidance lead to abandoned platforms and support tickets.
- **Business Impact:** Silent failures and poor quality erode user trust, increase churn, and can be linked to business failure.

Example:

Failing to validate user input may lead to SQL injection.

Exercise 3:

Identify possible vulnerabilities in a simple login process description.

Topic 7: Platform Technologies Security Domain (1 Hour)

Discussion:

Platform technologies include operating systems and computing environments.

Domain-Specific Concerns:

UNPATCHED SYSTEMS

Unpatched systems are devices or software missing crucial security updates, leaving known vulnerabilities exposed for cybercriminals to exploit, leading to data breaches, malware infections, ransomware, and system failures, creating significant risks for individuals and organizations despite patches being available to fix these security holes. Attackers often reverse-engineer released patches to develop exploits targeting systems that haven't updated, making prompt patch management essential for cybersecurity.

What are they?

1. Any device (computer, server, mobile) running outdated software or an old operating system with documented security flaws.
2. Systems running legacy software that manufacturers no longer support, meaning they won't receive new security fixes.

Why are they dangerous?

1. Easy Targets: Attackers actively scan for these known vulnerabilities, turning unpatched systems into simple entry points.
2. Data Breaches: Can expose sensitive data, leading to identity theft and financial loss.
3. [Malware & Ransomware](#): Vulnerabilities can deliver malware, spy on activities, or encrypt data for ransom.
4. System Downtime: Exploits can crash systems, disrupting operations.

Common Causes

1. Neglect: Delaying or forgetting to install updates.
2. Legacy Systems: Using old software that is no longer supported by vendors.
3. Third-Party Risks: Vulnerabilities in third-party software used by an organization.
4. Solutions
5. Patch Management: Implement a regular process for applying security updates.
6. Virtual Patching: Use security tools to block exploits before permanent patches are installed.
7. Retire Legacy Systems: Replace unsupported software and hardware.

MALWARE INFECTIONS

A malware infection happens when malicious software (malware) secretly enters a device to steal data, disrupt operations, or gain unauthorized control, often disguised as legitimate files or through compromised websites/emails, causing symptoms like slow performance, pop-ups, crashes, and disabled security tools, requiring detection and removal by antivirus software.

How it Happens

Malware spreads through various methods, including:

1. **Email Attachments:** Clicking on infected links or files in suspicious emails.
2. **Malicious Websites:** Visiting compromised or harmful websites that exploit software vulnerabilities.
3. **Infected Downloads:** Downloading compromised apps, games, or other software.
4. **Compromised USBs:** Infected flash drives carrying malware.
5. **Software Vulnerabilities:** Exploiting holes in outdated operating systems or browsers.

Common Types of Malware

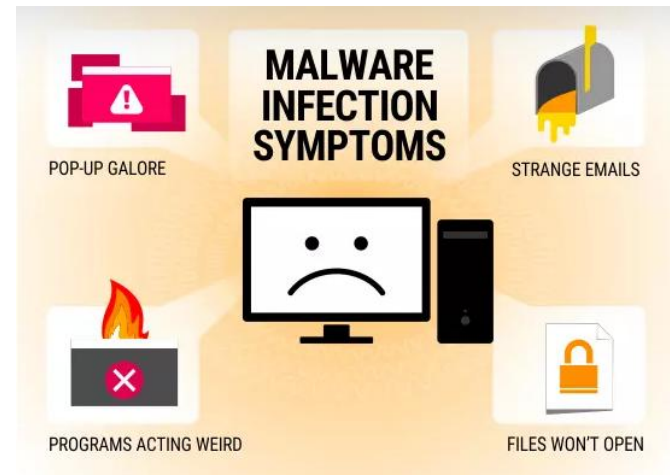
1. **Viruses & Worms:** Self-replicating code that spreads and damages systems.
2. **Trojans:** Disguised as useful programs but contain malicious functions.
3. **Ransomware:** Encrypts files and demands payment for their release.
4. **Spyware & Adware:** Steals information or bombards users with unwanted ads.

Signs of an Infection

1. **Performance Issues:** Slow computer, frequent crashes, or freezing.
2. **Unexpected Activity:** New toolbars, unfamiliar apps, or changes to browser settings/homepage.
3. **Excessive Pop-ups:** A sudden increase in ads, especially in strange places.
4. **Disabled Security:** Your antivirus or firewall stops working.
5. **High Network Usage:** Spikes in internet activity when idle.

Protection & Removal

1. **Install Antivirus:** Use reputable antivirus and anti-malware software.
2. **Keep Software Updated:** Patch your OS, browser, and applications regularly.
3. **Be Cautious:** Don't click suspicious links or open unknown attachments.
4. **Download Safely:** Only from official sources.
5. **Scan Devices:** Regularly scan for threats and remove any found.



MISCONFIGURED SETTINGS

Misconfigured settings are incorrect or suboptimal setups in software, hardware, or cloud services that create security vulnerabilities, cause system errors, or lead to unexpected behavior, often stemming from leaving defaults unchanged, overly permissive access, or errors in setup, allowing attackers to exploit these gaps for unauthorized access, data theft, or service disruption. Common examples include public cloud storage (S3 buckets), default passwords, open firewall ports (like SSH/RDP), and unnecessary enabled services, highlighting the need for strict security policies, automation, and regular audits.

Example:

Regular OS updates reduce vulnerability to attacks.

Activity

Create a basic security checklist for a personal computer.

3:

Topic 8: System Administration Security Domain (1 Hour)

Discussion:

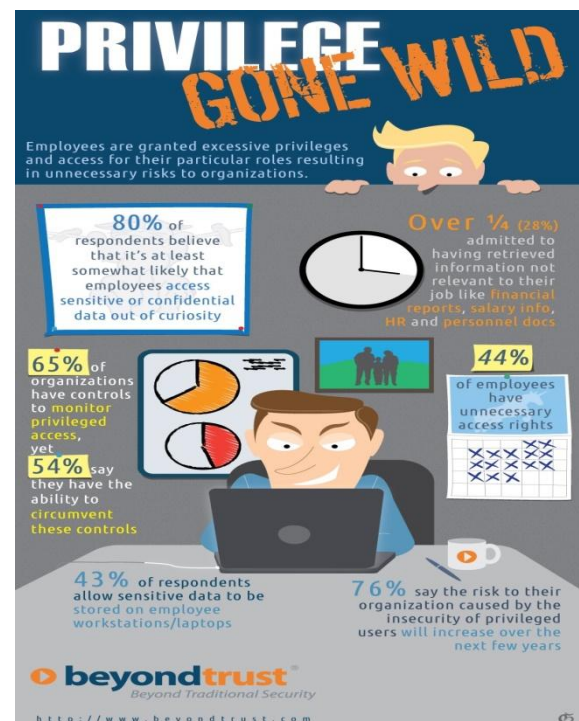
System administrators are responsible for configuring and maintaining secure systems.

Domain-Specific Concerns:

EXCESSIVE PRIVILEGES

Excessive privileges mean having more access rights or permissions in a system than needed for a job, creating a major security risk by expanding the attack surface for hackers or insider threats, often from "privilege creep" (accumulated old access) or misconfiguration, and violating the Principle of Least Privilege (PoLP). This over-per missioning allows compromised accounts to cause greater damage, leading to data breaches, system compromise, and compliance failures, making its removal crucial for security.

How it happens (Causes)



1. [Privilege Creep/Sprawl](#): Permissions aren't removed when employees change roles or leave, accumulating unnecessary rights over time.
2. Poor Design: Access control policies are poorly designed from the start.
3. Administrative Convenience: Broad access granted for ease of management.
4. Oversight: Lack of awareness or review processes.

Why it's dangerous (Risks)

1. Wider Attack Surface: More access means more opportunities for attackers if an account is compromised.
2. Increased Breach Impact: A compromised account can access sensitive data or damage systems beyond its intended scope.
3. Insider Threats: Malicious or negligent insiders can misuse excess rights for data theft or destruction.
4. Lateral Movement: Attackers can use excess privileges to move deeper into the network.

The Solution: [Principle of Least Privilege](#) (PoLP) - Granting only the minimum necessary permissions for a user or process to perform its job.

POOR BACKUP PRACTICES

Poor backup practices involve failing to follow the 3-2-1 rule (three copies, two media, one offsite), not testing restores, relying on single locations, ignoring errors, using inadequate methods like simple cloud sync, and lacking immutable storage, all leading to data loss from human error, ransomware, hardware failure, or corruption. Key mistakes include storing backups with original data, not verifying backups, and assuming cloud sync equals true backup, leaving businesses vulnerable when disaster strikes.

Common Poor Backup Practices

1. No 3-2-1 Rule: Keeping all data in one place (e.g., on the same server or local drive) risks total loss if that single location fails.
2. Not Testing Restores: Assuming backups work without regular, successful test restores means you won't know if data is corrupted or incomplete until it's too late.
3. Ignoring Alerts: Overlooking backup job failures or error messages leads to incomplete or corrupted backups.
4. Relying on Cloud Sync: Tools like Dropbox sync files but aren't true backup solutions; they can replicate deleted or corrupted files.
5. Lack of Immutability: Not using immutable storage allows ransomware or accidental changes to corrupt backups.
6. Incomplete Backups: Misconfigured settings might exclude critical files, databases, or entire application dependencies.
7. Poor Media Choice: Using cheap USB drives for long-term backups because flash memory degrades quickly

Example:

Granting administrator access only when necessary.

Exercise**4:**

Respond to a scenario involving a suspected system breach.

Topic 9: Systems Integration and Architecture Security Domain (1 Hour)**Discussion:**

This domain focuses on designing secure systems and integrating multiple components safely.

Domain-Specific Concerns:**Insecure APIs**

Insecure APIs are vulnerable interfaces lacking proper security, allowing attackers to exploit weaknesses like broken authentication, injection flaws, or excessive data exposure to steal data, disrupt services ([DoS](#)), or gain unauthorized access, with common causes being poor design, misconfigurations, outdated components, and insufficient logging. Key risks include data breaches, operational outages, compliance failures (GDPR, HIPAA), and reputational damage, necessitating strong authentication, encryption, rate limiting, input validation, and robust monitoring.

Weak trust boundaries

Weak trust boundaries in cybersecurity refer to points in an application or network where the separation between trusted and untrusted data is unclear or improperly enforced. This vulnerability occurs when unvalidated input from a user or external source is treated as trusted, allowing attackers to exploit the system.

Key Aspects of Weak Trust Boundaries:

1. Definition: A trust boundary acts as a line within a program separating trusted, validated data from unvalidated, untrusted data.
2. Violation (CWE-501): Occurs when a program blends these data types in the same data structure, causing the system to mistakenly trust malicious input.
3. Common Causes: Failing to validate inputs, such as accepting unverified cookies, or mixing user-controlled data with system-level data.
4. Consequences: Exploitation can lead to data breaches, unauthorized access, and lateral movement within a network.

5. Prevention: Utilizing threat modeling to identify and manage these boundaries, along with strict validation logic.

Examples of Weak Trust Boundary Violations:

1. Web Applications: Storing user input (like a username) in a session object before confirming the user is authenticated.
2. Network Security: Lack of micro-segmentation, allowing an attacker to move freely after compromising one part of the system.

Example:

Using layered security (defense-in-depth).

Activity

4:

Review a sample system architecture and identify risks.

Topic 10: Web Systems and Physical Plant Security Domains (1 Hour)

Web Systems Discussion:

Web systems security focuses on protecting web applications and services.

Concerns:

Cross-site scripting (XSS)

Cross-site Scripting (XSS) is a prominent web security vulnerability that allows attackers to inject malicious client-side scripts—usually JavaScript—into trusted websites. These scripts execute within the browsers of unsuspecting users, enabling attackers to bypass the Same-Origin Policy and compromise user interactions.

How XSS Works

The attack typically occurs in two stages:

1. Injection: The attacker finds a vulnerability in a web application (like a comment field or search bar) and injects a malicious script (payload).
2. Execution: When a victim visits the compromised page or clicks a malicious link, their browser treats the script as legitimate code from the trusted site and executes it.

Main Types of XSS Attacks

1. Reflected XSS (Non-persistent): The malicious script is "reflected" off a web server. It is typically delivered via a crafted link in a phishing email or social media post.
2. Stored XSS (Persistent): The payload is permanently stored on the target server (e.g., in a database or forum comment). Every user who visits the infected page becomes a victim.
3. DOM-based XSS: The vulnerability exists entirely in the client-side code rather than the server-side code. The script executes by manipulating the Document Object Model (DOM).

Consequences of XSS

A successful XSS attack can have severe impacts, including:

Session Hijacking: Stealing session cookies to impersonate a user and take over their account.

Data Theft: Capturing sensitive information like login credentials, credit card details, or PII.

Site Defacement: Modifying the content of a webpage to display offensive material or false information.

Malware Distribution: Using the compromised site to trick users into downloading malicious software.

Prevention Strategies

1. To protect against XSS, developers should implement a defense-in-depth approach:
2. Filter and Validate Input: Treat all user input as untrusted and filter it against a whitelist of expected values.
3. Encode Data on Output: Use context-aware encoding (HTML, URL, or JavaScript encoding) before rendering user-controllable data to ensure it is interpreted as text, not code.
4. Use Content Security Policy (CSP): Implement a strict CSP header to restrict which scripts the browser is allowed to execute.
5. Set Cookie Flags: Use the HttpOnly flag to prevent client-side scripts from accessing sensitive session cookies

SQL injection

SQL Injection (SQLi) is a dangerous cyberattack where malicious SQL code is inserted into data-driven application inputs (like login forms) to trick the database into executing unwanted commands, potentially revealing, altering, or deleting sensitive data, or even taking control of the database server. It exploits flaws where user input isn't properly sanitized, allowing attackers to bypass security and manipulate database queries.

How it works

1. Attackers find input fields (search bars, login forms) that build SQL queries dynamically.

2. They insert special SQL characters (like single quotes ') that break the intended query structure.
3. If vulnerable, the database executes the attacker's added SQL, not the original command.

Example

1. Normal login: `SELECT * FROM users WHERE username = 'user1' AND password = 'password1';`
2. Malicious input: `' OR '1'='1`
3. Resulting query (vulnerable): `SELECT * FROM users WHERE username = " OR '1'='1' AND password = ";` (This often returns all users because `'1'='1'` is always true, bypassing password check).

Prevention

1. Parameterized Queries/Prepared Statements: The most effective method; separates SQL code from user data.
2. Input Validation & Sanitization: Checking and cleaning user input for malicious characters.
3. Least Privilege: Giving database accounts only necessary permissions.
4. Web Application Firewalls (WAFs): Can block common SQLi attempt

Session hijacking

Session hijacking is a cyberattack where a malicious actor takes control of a user's active web session by stealing or manipulating the session ID, allowing them to impersonate the legitimate user and gain unauthorized access to data and services. This attack can bypass traditional authentication methods, including multi-factor authentication (MFA), because it exploits an already-authenticated session.

How Session Hijacking Works

When a user logs into a website, the server creates a unique session ID (often stored in a browser cookie) to maintain the "state" of the user's interaction (e.g., keeping items in a shopping cart) without requiring re-authentication on every page. An attacker compromises this session ID through various methods to gain the same privileges as the legitimate user.

Common Attack Techniques

1. Attackers use several methods to steal or compromise session IDs:
2. Session Sniffing/Sidejacking: Intercepting unencrypted network traffic (especially on public Wi-Fi) to capture session cookies or tokens.
3. Cross-Site Scripting (XSS): Injecting malicious scripts into vulnerable web pages that, when executed in the victim's browser, steal their session cookies and send them to the attacker.
4. Session Fixation: Tricking a user into using a predetermined session ID, often through a malicious link in a phishing email. Once the user logs in with that ID, the attacker can use the known ID to access the authenticated session.

5. Malware/Infostealers: Infecting the user's device with malicious software that harvests browser cookies and authentication tokens from local storage.
6. Predictable Session IDs: Exploiting weak algorithms used by web servers to generate session IDs, allowing attackers to guess or calculate a valid ID.
7. Man-in-the-Middle (MitM): Positioning themselves between the user and the server to intercept and potentially alter all communication, including the session token.

Impacts and Consequences

A successful session hijacking attack can lead to severe consequences for both individuals and organizations:

Unauthorized Access & Data Theft: Attackers gain access to sensitive information like personal data, financial records, and corporate secrets.

1. Financial Loss: Attackers can perform unauthorized transactions, transfer funds, or make purchases using the victim's account.
2. Identity Theft: Stolen information can be used to impersonate the victim across various online platforms.
3. Reputational and Financial Damage for Businesses: Organizations face data breaches, loss of customer trust, regulatory fines (e.g., GDPR, HIPAA violations), and legal challenges.

Prevention and Detection

Prevention is the most effective strategy against session hijacking.

For Individual Users

1. Avoid Public Wi-Fi for Sensitive Tasks: Unsecured networks are highly vulnerable to session sniffing. Use a VPN (Virtual Private Network) if you must use public Wi-Fi.
2. Log Out Explicitly: Always sign out of accounts when finished, especially on shared or public computers, to invalidate the session token.
3. Be Aware of Phishing: Avoid clicking on suspicious links in emails or messages that might lead to malicious sites designed to steal session information.
4. Use Security Software: Keep your operating system, browser, and antivirus software updated to protect against malware.

For Developers and Organizations

1. Enforce HTTPS/TLS Encryption: Encrypt all traffic between the client and server to prevent network-level sniffing attacks.
2. Implement Secure Session Management:
3. Generate long, random, and cryptographically secure session IDs.
4. Regenerate the session ID after significant events like a successful login or privilege change to prevent session fixation.
5. Set short, automatic session timeouts for inactivity.

6. Use secure cookie flags (HttpOnly and Secure) to restrict access to session cookies from client-side scripts and ensure they are only sent over HTTPS.
7. Monitor for Anomalies: Implement systems to detect unusual activity, such as logins from different IP addresses within an impossible timeframe, multiple concurrent sessions, or abnormal request patterns.
8. Use MFA (Multi-Factor Authentication): While not a complete defense, MFA adds an extra layer of security, making it harder for an attacker to gain initial access, though a compromised active session may still bypass it.

Physical Plant Discussion:

Physical plant security protects facilities and hardware.

Concerns:

Unauthorized physical access

[Unauthorized physical access](#) means someone enters a secure area or gains control of physical assets (like servers, devices, or buildings) without permission, violating security policies and risking data theft, damage, or disruption, often through methods like tailgating, stolen keys, or social engineering. It's a critical security threat, similar to digital hacking, and requires strong physical security measures (locks, access controls, surveillance) and employee training to prevent.

What it is

1. Gaining entry to restricted premises (offices, data centers) or devices (laptops, servers) without authorization.
2. Violating an organization's security policy, whether accidentally or maliciously.

Common methods

1. [Tailgating](#)/Piggybacking: Following an authorized person through a secured entry point.
2. Stolen/Lost Credentials: Using stolen keys, badges, or fobs to get in.
3. Social Engineering: Tricking authorized personnel into granting access.
4. Bypassing Security: Forcing entry through weak doors or exploiting smart lock vulnerabilities.
5. Theft: Stealing devices containing sensitive data.

Risks

1. Data Breaches: Stealing confidential information.
2. Vandalism & Sabotage: Damaging property or systems.
3. Espionage: Spying and stealing trade secrets.
4. Safety Threats: Endangering employees and disrupting operations.

Prevention

1. Access Control: Key cards, biometric scanners, visitor management.
2. Surveillance: CCTV monitoring and alarms.
3. Policies: Strict rules on visitor access, tailgating, and lost credentials.
4. Training: Educating staff to recognize and report suspicious behavior and social engineering attempts

Environmental threats

Environmental threats to computer and information systems include physical hazards (fire, water, extreme temperatures, dust, contaminants) damaging hardware and causing downtime, and cyber-environmental risks, where attacks on IT systems controlling infrastructure (like power grids or water treatment) cause direct ecological harm, plus broader issues like e-waste and manufacturing pollution from device production. These threats affect system reliability, data integrity, and the environment itself through energy consumption and toxic disposal.

Physical & Operational Threats

Temperature & Humidity: Overheating from high temperatures or excessive humidity can damage components; extreme cold can also be problematic.

Dust & Contaminants: Dust, lint, skin particles, and pollutants (like sea salt or construction dust) can clog vents, cause shorts, and lead to failure.

Water & Fire: Leaks, floods, and fires (often from electrical issues) can destroy equipment, with smoke and chemicals causing further damage.

Power Fluctuations: Surges, sags, or outages can corrupt data or damage hardware, requiring robust power management.

Cyber-Environmental Threats

Attacks on Critical Infrastructure: Hacking into systems for water treatment, energy grids, or pollution monitoring can lead to direct environmental damage, such as spills or blackouts.

Data Breaches During Disaster Recovery: Natural disasters can force reliance on vulnerable backup systems, creating opportunities for attackers to steal data.

Broader Environmental Impacts (Manufacturing & Disposal)

E-Waste: Rapid tech cycles create mountains of electronic waste containing hazardous materials (lead, mercury) that pollute soil and water if not recycled.

Resource Depletion & Pollution: Mining for rare earth minerals, energy-intensive manufacturing, and global transportation contribute to deforestation, water pollution, and greenhouse gas emissions.

Energy Consumption: Data centers and device usage consume massive amounts of electricity, increasing carbon footprints.

Threat Mitigation

Physical: Environmental monitoring, proper cooling, air filtration, fire suppression, and robust backup power.

Cyber: Strong cybersecurity for operational technology (OT) and IT systems, data encryption, and secure disaster recovery plans.

Sustainability: Responsible e-waste recycling, energy-efficient practices, and designing for longevity.

Exercise

5:

Compare cyber security controls and physical security controls in a school.

Assessment Summary

- Quizzes
 - Written exercises
 - Group activities and discussions
-

References

- Whitman, M. E., & Mattord, H. J. (2022). *Principles of Information Security*. Cengage Learning.
 - Stallings, W. (2021). *Computer Security: Principles and Practice*. Pearson.
 - ISO/IEC 27001: Information Security Management Systems.
 - NIST SP 800-53: Security and Privacy Controls for Information Systems.
 - OWASP Foundation. *OWASP Top 10 Web Application Security Risks*.
-

Module Summary

This module provides students with a holistic understanding of security domains and their role in protecting information systems. By recognizing both shared and domain-specific security

concerns, learners gain essential knowledge applicable to professional practice and everyday digital activities.